CƠ CHẾ XÁC THỰC HAI LỚP (2FA)

VinaSocial | Tài liệu tóm lược phục vụ thuyết trình | 06/11/2026

Tổng quan

VinaSocial bảo vệ đăng nhập bằng **mật khẩu** và **OTP 6 chữ số** gửi đến email hoặc số điện thoại đã xác minh. OTP được UserService tạo riêng cho từng yêu cầu; đây không phải TOTP từ ứng dụng xác thực.

Thành phần	Trách nhiệm
UserService	Xác thực mật khẩu, tạo và kiểm tra OTP, quản lý trạng thái 2FA, cấp token.
MySQL	Lưu tài khoản, challenge OTP và phiên đăng nhập.
Kafka	Chuyển sự kiện OTP bảo mật qua topic **auth_otp_security**.
NotificationService	Gửi OTP đến email hoặc số điện thoại.

Điều kiện và dữ liệu

Tài khoản phải có ít nhất một email hoặc số điện thoại **đang hoạt động và đã xác minh**. Hệ thống chọn địa chỉ phù hợp đầu tiên để nhận mã.

Cột **users.two_factor_enabled** lưu trạng thái bật/tắt, mặc định là **false**. Bảng **auth_otps** lưu publicId, người dùng, địa chỉ nhận, mục đích, thời điểm tạo/hết hạn/xác minh, mã đã mã hóa và số lần nhập sai.

Ba mục đích OTP bảo mật

- **LOGIN:** hoàn tất đăng nhập sau khi mật khẩu đã đúng.
- **ENABLE_MFA:** xác nhận bật 2FA.
- **DISABLE_MFA:** xác nhận tắt 2FA.

UserService đối chiếu mục đích của challenge; khi bật hoặc tắt còn đối chiếu chủ sở hữu với tài khoản đang thực hiện. API OTP chung không xác minh hoặc gửi lại ba loại OTP này.

Quy trình bật 2FA

- Yêu cầu có phiên đăng nhập và xác thực lại mật khẩu hiện tại.
- UserService tạo challenge **ENABLE_MFA** và phát sự kiện gửi OTP.
- OTP hợp lệ làm **two_factor_enabled = true** và thu hồi tất cả refresh session hiện có.

Quy trình đăng nhập

- UserService xác thực tên đăng nhập và mật khẩu.
- Nếu 2FA tắt, hệ thống tạo phiên và cấp token sau khi mật khẩu đúng.
- Nếu 2FA bật, hệ thống tạo challenge **LOGIN** và gửi OTP; **chưa cấp access token hoặc refresh token**.
- Sau khi OTP hợp lệ, UserService tạo hoặc cập nhật phiên, cấp access token và đặt refresh token trong cookie.

Quy trình tắt 2FA

Người dùng cần phiên đăng nhập, mật khẩu hiện tại và OTP **DISABLE_MFA**. Xác minh thành công chuyển **two_factor_enabled = false**; các lần đăng nhập sau chỉ cần mật khẩu.

Vòng đời và kiểm tra OTP

- Mã gồm 6 chữ số, được tạo bằng **SecureRandom**, có hiệu lực **90 giây**.
- Challenge bị từ chối nếu hết hạn, đã dùng hoặc có **5 lần nhập sai**. Số lần sai vẫn được lưu khi yêu cầu trả lỗi.
- Mã đúng được đánh dấu thời điểm xác minh để không thể dùng lại.
- Nếu challenge cùng mục đích vẫn còn hạn và chưa xác minh, hệ thống có thể trả lại challenge đó thay vì phát mã mới.

Mã hóa và giải mã OTP

Các OTP dùng **một khóa AES-256 chung**. Mỗi lần mã hóa tạo một **IV ngẫu nhiên 12 byte riêng** và dùng publicId của challenge làm **AAD**. AES-GCM tạo thẻ xác thực 128 bit; giá trị lưu trong MySQL có dạng **v1.<IV-base64url>.<ciphertext-base64url>**.

Khi xác minh, UserService đọc IV và bản mã, dùng **cùng khóa AES** và publicId để giải mã. Nếu sai khóa, sai publicId hoặc bản mã bị sửa, kiểm tra xác thực của AES-GCM thất bại. Sau đó service so sánh OTP giải mã được với mã người dùng cung cấp.

Khóa được cấu hình dưới dạng Base64 biểu diễn đúng 32 byte và phải giữ ổn định giữa các lần khởi động cũng như giữa các instance UserService. Mã nguồn còn đọc được OTP cũ dạng rõ để tương thích với bản ghi trước khi áp dụng mã hóa.

> **Một khóa chung không tạo ra bản mã giống nhau cho các OTP giống nhau, vì mỗi lần mã hóa sử dụng IV ngẫu nhiên riêng.**

Token và phiên đăng nhập

Refresh token được đặt trong cookie **HttpOnly, Secure, SameSite=None**. Cấu hình hiện tại đặt thời hạn access token là **10 phút** và refresh token là **24 giờ**. Khi bật 2FA, các refresh session cũ bị thu hồi nên không thể làm mới phiên; access token đã cấp có thể tiếp tục hiệu lực đến lúc hết hạn.

Giới hạn và lưu ý bảo mật

- Mã hóa AES-GCM bảo vệ OTP **khi lưu trong MySQL**. Sự kiện Kafka vẫn mang OTP dạng rõ để NotificationService gửi đi; cần bảo vệ quyền truy cập và kênh truyền của topic.
- Nếu khóa AES chung bị lộ cùng dữ liệu OTP, các challenge còn hiệu lực có thể bị giải mã. Mất khóa khiến các challenge đã mã hóa không thể xác minh.
- Độ an toàn của yếu tố thứ hai phụ thuộc vào email hoặc SIM nhận mã. Chưa có TOTP, khóa bảo mật phần cứng hay mã khôi phục.
- Chưa có quy trình khôi phục 2FA khi mất quyền truy cập email/SMS; cũng chưa hỗ trợ chọn kênh nhận cho từng lần xác thực.